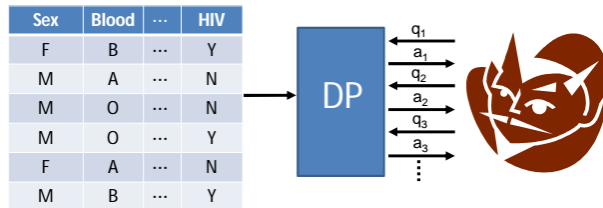


Chapitre 1

Confidentialité en Statistiques



données (cf essais cliniques).

Problème : ça pourrait révéler des informations confidentielles sur les individus. Certaines informations personnelles sont sensibles : dossiers médicaux, informations commerciales, métadonnées de courriels, etc.

Comment faire pour assurer le respect de la vie privée des personnes ?

1.1 Introduction

1.1.1 Motivation

“ L’évolution rapide des technologies et la mondialisation ont créé de nouveaux enjeux pour la protection des données à caractère personnel. L’ampleur de la collecte et du partage de données à caractère personnel a augmenté de manière importante. Les technologies permettent tant aux entreprises privées qu’aux autorités publiques d’utiliser les données à caractère personnel comme jamais auparavant dans le cadre de leurs activités. De plus en plus, les personnes physiques rendent des informations les concernant accessibles publiquement et à un niveau mondial. ”

Préambule (paragraphe 6) du RGPD = Règlement général sur la protection des données, adopté en avril 2016, entré en application le 25 mai 2018.

Actuellement : forte utilisation de bases de données, souvent contenues dans des serveurs centralisés.

Analystes y accèdent pour faire analyses statistiques globales, voire même partage de

1.1.2 Représentation

Les données à caractère personnel peuvent en général être mises sous forme d’un tableau de ce type :

Numéro de sécu	Age	Code postal	Diagnostic
2431075123123	75	75005	Cancer
2780875123123	40	75012	Grippe
1060575123123	12	78000	Grippe
1931275123123	25	75005	VIH
1881175123123	30	92100	Allergie

1.2 Pseudonymisation

Méthode la plus naturelle pour garantir la confidentialité : masquer le nom ou l’identifiant, le remplacer par un pseudonyme (sans lien avec l’identifiant).

Pseudonyme	Age	Code postal	Diagnostic
a	75	75005	Cancer
b	40	75012	Grippe
c	12	78000	Grippe
d	25	75005	VIH
e	30	92100	Allergie

Pseudonyme créée par une fonction de hachage sur un des identifiants (par exemple : numéro sécu).

1.2.1 Données médicales du Massachussets (2022)

- Sweeney (2002) a croisé deux bases de données :
- base de données de visites médicales pseudonymisée
 - liste électorale avec des données nominatives

Croisement effectué sur un triplet de valeurs : code postal, date de naissance et sexe (unique pour environ 80% de la population des États-Unis).

Elle a pu retrouver des données médicales de certains individus (en l'occurrence le gouverneur de l'Etat).

Conclusion : La pseudonymisation ne suffit pas !

En particulier à cause de la présence d'informations extérieures à la base de données considérée.

1.2.2 AOL (2006)

En 2006, diffusion des mots-clés utilisés par 500 000 abonnés américains dans le moteur de recherche AOL pendant 3 mois (soit environ 20 millions d'entrées, non censurées ni filtrées).

AnonID	Query	QueryTime
1326	"holiday mansion houseboat"	2006-03-29
1326	"back to the future"	2006-04-01
591476	"english spanish translator"	2006-03-20
591476	"panama vacations"	2006-03-20
591476	"breast reduction"	2006-03-23
591476	"volunteer work at hospitals in brooklyn"	2006-05-24
591476	...	...
591476	"how to secretly poison your ex"	2006-03-12

Recherches rendues anonymes mais permettent d'identifier certains utilisateurs (par exemple plusieurs personnes ont recherché des informations sur elles-mêmes).

Remarque : Certaines recherches portaient sur pratiques illégales !

Deux journalistes du New York Times ont pu localiser un individu à partir des enregistrements de recherche publiés et anonymisés, en les croisant avec l'annuaire.

1.2.3 Prix Netflix (2007)

En 2007, Netflix offrait 1 000 000 \$ à quiconque pourrait améliorer de 10% son système de recommandation → fournit un jeu de données permettant aux candidats d'entraîner leurs modèles.

Identifiants clients remplacés par des identifiants aléatoires

Arvind Narayanan et Vitaly Shmatikov (Université du Texas) ont réussi à ré-identifier une partie de ces données à partir des notes attribuées par les membres d'IMDb (Internet Movie Database).

1.2.4 Études d'association pangénomique

Etude d'association pangénomique (Genome Wide Association Study) = analyse de nombreuses variations génétiques chez de nombreux individus, afin d'étudier leurs corrélations avec des traits phénotypiques.

Homer et al. (2008) ont montré qu'il est possible de vérifier avec une grande confiance si un individu a participé à une étude d'association pangénomique (GWAS).

Peu de temps après la publication, le National Institute of Health (NIH) des États-Unis a retiré tous les résultats agrégés de sa base de données en ligne dbGaP, une ressource clé pour la recherche biomédicale à composante génétique.

1.2.5 Attaques différentielles

Et si on n'autorise que des requêtes globales sur la base de données ?

Nom	Vincent	Agathe	Martin	Hélène	Sophie
A le diabète	1	1	0	0	1

Seule requête possible F_i : renvoie la somme partielle des i premières colonne de la base de données.

Si on sait Sophie = colonne 5, on demande F_5 et F_4 , puis on calcule $F_5 - F_4 = 3 - 2 = 1$, donc valeur attribuée à Sophie est 1.

Ici : pas de demande d'information individuelle, et peu importe taille de la base de données.

1.3 Méthode d'anonymisation

“ Pour déterminer si une personne physique est identifiable, il convient de prendre en considération l'ensemble des moyens raisonnablement susceptibles d'être utilisés (...) pour identifier la personne physique (...). Il n'y a dès lors pas lieu d'appliquer les principes relatifs à la protection des données aux informations anonymes, à savoir les informations ne concernant pas une personne physique identifiée ou identifiable, ni aux données à caractère personnel rendues anonymes de telle manière que la personne concernée ne soit pas ou plus identifiable. ”

(Préambule du RGPD, paragraphe 26)

Comment vérifier l'efficacité de l'anonymisation ?

Les autorités de protection des données européennes définissent trois critères qui permettent de s'assurer qu'un jeu de données est véritablement anonyme :

1. l'individualisation : il ne doit pas être possible d'isoler un individu dans le jeu de données ;

Exemple : une base de données de CV où seuls les nom et prénoms d'une personne auront été remplacés par un numéro (qui ne correspond qu'à elle) permet d'individualiser cette personne. Dans ce cas, cette base de données est considérée comme pseudonymisée et non comme anonymisée.

2. la corrélation : il ne doit pas être possible de relier entre eux des ensembles de données distincts concernant un même individu ;

Exemple : une base de données cartographique renseignant les adresses de domiciles de particuliers ne peut être considérée comme anonyme si d'autres bases de données, existantes par ailleurs, contiennent ces mêmes adresses avec d'autres données permettant d'identifier les individus.

3. l'inférence : il ne doit pas être possible de déduire, de façon quasi certaine, de nouvelles informations sur un individu.

Exemple : si un jeu de données supposément anonyme contient des informations sur le montant des impôts de personnes ayant répondu à un questionnaire, que tous les hommes ayant entre 20 et 25 ans qui ont répondu sont non imposables, il sera possible de déduire, si on sait que M. X, homme âgé de 24 ans, a répondu au questionnaire, que ce dernier est non imposable.

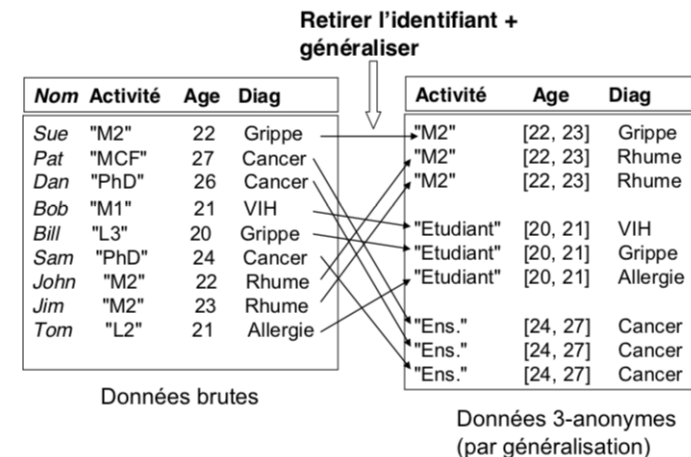
1.3.1 k -anonymat

Le k -anonymat : créé pour contrer l'attaque de Sweeney.

Séparation des attributs de chaque personne :

- quasi-identifiants (typiquement age + adresse + sexe)
- données sensibles (typiquement diagnostic médical)

Regrouper les individus de façon à ce qu'il y ait au moins k personnes qui aient les mêmes quasi-identifiants, quitte à réduire le niveau de détail des données : âge exact transformé en intervalles d'âge, ville en région, profession en secteur d'activité,...



1.3.2 Autres méthodes de généralisation

Le modèle de l -diversité répond à certains problèmes du k -anonymat, il impose une diversité des données sensibles dans chaque groupe.

La t -proximité fait des regroupements et utilise la distribution des données sensibles, mais fournit des données pas toujours exploitables.

De nombreuses approches visant à anonymiser des documents publics (telles que le k -anonymat) ont échoué quand les chercheurs ont réussi à identifier les données personnelles en reliant plusieurs bases de données séparément inoffensives.

1.3.3 Confidentialité différentielle

Techniques basées sur l'aléatoire.

Donne des garanties formelles (preuves mathématiques) sur la possibilité de retrouver des informations personnelles.



1.3.4 Décentralisation

Démarches actuelles : plutôt décentraliser le traitement des données, sortir du schéma où un tiers de confiance est dépositaire d'une base de données d'informations sensibles.

Chaque personne concernée pourrait gérer elle-même son stockage sur le cloud.

1.4 Limites et garanties

1.4.1 Un concept social

Qu'est-ce que la vie privée ?

Qu'est-ce qu'une société donnée considère relever de la vie privée ?

Très difficile de définir une bonne notion de confidentialité.

Remarque : Dans notre société, on ne considère pas qu'il suffit de protéger la plupart des gens, on considère qu'une bonne méthode doit protéger tout le monde.

1.4.2 Confidentialité totale impossible

Exemple jouet : étude sur la cigarette.

Une étude médicale prouve que le tabagisme cause le cancer.

Cette étude peut nuire à Monsieur X fumeur (augmentation assurance santé, stress) ou l'aider (décide d'arrêter de fumer).

Question : la vie privée de Monsieur X a-t-elle été compromise par l'étude ? (on en sais plus sur lui après qu'avant l'étude)

On peut considérer que pas de perte de confidentialité car le résultat est le même qu'il soit dans l'étude ou pas.

Notion qu'on choisira plus tard : il y a confidentialité si on en sait presque autant, que Monsieur X soit ou pas dans l'étude

1.4.3 Données personnelles

Confidentialité totale impossible → on se base beaucoup sur le principe des données personnelles.

Notion de donnée personnelle complexe : par exemple, les données médicales de ses descendants/ascendants sont reliées aux nôtres.

“ On entend par “données à caractère personnel”, toute information se rapportant à une personne physique identifiée ou identifiable ; est réputée être une “personne physique identifiable” une personne physique qui peut être identifiée, directement ou indirectement, notamment par référence à un identifiant, tel qu'un nom, un numéro d'identification, des données de localisation, un identifiant en ligne, ou à un ou plusieurs éléments spécifiques propres à son identité physique, physiologique, génétique, psychique, économique, culturelle ou sociale. ”

(Article 4 du RGPD.)

1.4.4 Données sensibles

Qu'est-ce qu'une donnée identifiante ? : âge ? code postal ? les films qu'on aime ?

Difficile aussi d'identifier les données « sensibles ».

Exemple jouet : achat du pain

Monsieur T achète régulièrement du pain (cette info paraît ordinaire, non-sensible)

Un jour il se met à acheter du pain plus rarement.

On pourrait conclure que Monsieur T a probablement été diagnostiqué avec un diabète de type 2.

1.4.5 Compromis confidentialité - utilité

Facile d'anonymiser, tant qu'on ne fait pas attention à préserver l'utilité des données publiées : il suffit de publier des données complètement aléatoires ! (ou de ne rien diffuser du tout)

Mais on a toujours besoin que les données restent utilisables à des fins statistiques avec des conclusions non-faussees (ou pas trop).

Balance privacy-utility, ou confidentialité-utilité

1.5 Rôle de l'aléatoire

1.5.1 Utilisation de l'aléatoire

Technique développée en sciences sociales (Warner, 1965) pour collecter des informations statistiques sur les comportements gênants ou illégaux (drogue, vie sexuelle, ...).

On demande à une personne de répondre à la question « Avez-vous déjà fait l'action A » selon le déroulement suivant :

- Lancer une pièce. Si pile, alors répondre honnêtement
- Si face, alors lancer à nouveau la pièce et répondre « Oui » si face, « Non » si pile

Confidentialité individuelle : réponse « Oui » ne signifie pas qu'on a nécessairement fait l'action A (ça peut juste être qu'on a obtenu face-face).

Utilité globale : si p est la proportion véritable de personnes ayant fait A, alors on va obtenir comme nombre moyen de « Oui » :

$$\frac{1}{2}p + \frac{1}{4} \rightarrow \text{estimation possible de } p.$$

1.5.2 Nécessité de l'aléatoire

En fait, toute garantie de confidentialité non-triviale qui tient compte de toutes les sources d'information auxiliaires présentes ou futures (autres bases de données, études, sites web, communautés en ligne, potins, journaux, statistiques gouvernementales, etc.) nécessite de l'aléatoire.

Preuve par l'absurde en utilisant attaque différentielle. On suppose qu'il existe une requête f et deux bases de données telles que $f(D) \neq f(D')$. On peut passer de D à D' en passant par des bases de données $D_1, \dots, D_k$ telles que D_i et D_{i+1} ne diffèrent que par la valeur d'une seule ligne. Puisque $f(D) \neq f(D')$, nécessairement il existe $j \in \{0, \dots, k\}$ tel que $f(D_j) \neq f(D_{j+1})$. Un adversaire sachant que la base de données est l'une de ces deux bases de données presque identiques apprend la valeur des données grâce à la ligne différente.

1.6 Ce qui ne sera pas abordé dans ce cours

Ce qui ne sera pas abordé dans ce cours sont :

- questions légales,
- questions de cryptographie, sécurité informatique
- questions de complexité algorithmique
- questions de mise en œuvre des algorithmes de confidentialité, architecture